

UE04 Produit et storytelling

Audit RGPD et sécurité, plan de remédiation et pilotage agile

Modalités : travail individuel, 4 jours.

IA générative autorisée, sous conditions (voir section 4). Un livrable généré sans travail d'analyse, de vérification et de mise en contexte sera noté comme tel.

1. Contexte

Une start-up édite une plateforme B2B de bien-être au travail : les salariés des entreprises clientes créent un compte, renseignent un questionnaire de santé, suivent leurs séances de sport, échangent avec des coachs. Les RH de l'entreprise cliente disposent d'un tableau de bord. Un assureur partenaire reçoit des exports.

La plateforme a grandi vite. Un grand compte exige un audit avant de renouveler son contrat, et un fichier contenant des données d'utilisateurs a été signalé sur un forum.

Le code source et une base de démonstration vous sont fournis :
supports/wellwork-platform.

2. Travail demandé

Partie A : cartographie et conformité

1. Registre des traitements (article 30) : finalités, catégories de données et de personnes, destinataires, transferts, durées de conservation.
2. Analyse de la base légale de chaque traitement et du statut des acteurs (responsable, sous-traitant, responsables conjoints).
3. Analyse d'impact (AIPD) : démontrez si elle est obligatoire, puis réalisez-la sur le traitement le plus risqué.
4. Constats de non-conformité : pour chacun, l'article concerné, la preuve dans le code, les données ou l'interface, le risque pour les personnes, la gravité.

Partie B : audit de sécurité

1. Constats de sécurité : description, preuve reproductible **sur votre instance**, impact, score CVSS avec vecteur, correspondance OWASP.
2. Lien entre constats de sécurité et RGPD : quelles failles constituent un risque de violation de données, et lesquelles ont pu causer la fuite signalée.
3. Violation de données : analysez l'obligation de notification (articles 33 et 34) et rédigez la notification à la CNIL et le message aux personnes concernées si nécessaire.

Partie C : remédiation

1. Plan de remédiation priorisé : actions immédiates, court terme, structurelles. Chaque action est reliée aux constats qu'elle traite.

2. Correctifs appliqués sur une branche dédiée pour au moins 5 constats, dont 2 RGPD et 2 sécurité, avec un commit par correctif et un test ou une preuve de non-régression.
3. Constats résiduels acceptés : justification et responsable de l'acceptation.

Partie D : méthodologie agile

Planifiez la mise en œuvre de la remédiation par une équipe de votre choix (à décrire et justifier).

1. Backlog : epics, user stories et abuser stories, critères d'acceptation vérifiables.
2. Estimation et priorisation avec une méthode justifiée (risque, valeur, effort).
3. Découpage en sprints : objectif de chaque sprint, contenu, capacité, dépendances.
4. Definition of Done intégrant sécurité et conformité.
5. Cérémonies, rôles (dont DPO et RSSI), indicateurs de suivi, gestion des risques du projet.

Partie E : restitution

Présentation de 5 minutes destinée au comité de direction de la start-up : situation, risques, plan, budget, décisions attendues. Pas de jargon non expliqué.

3. Livrables

- Dossier de remédiation PDF (30 pages maximum hors annexes) : parties A à D.
- Branche de correctifs sur le dépôt.
- Support de présentation de la partie E.
- Annexe de transparence IA (voir section 4).

4. Usage de l'IA

L'IA est autorisée comme outil. Le dossier doit contenir une annexe indiquant :

- les outils utilisés et pour quelles parties ;
- les principales requêtes formulées ;
- au moins 5 erreurs, imprécisions ou contenus génériques produits par l'IA que vous avez détectés, avec la correction apportée et la source qui la justifie.

Sont pénalisés : constats sans preuve issue du projet, références juridiques non vérifiées ou inexactes, recommandations génériques non reliées au code, incohérences entre les parties. L'oral peut porter sur n'importe quel élément du dossier.

5. Barème

Partie	Points
A. Cartographie et conformité	4
B. Audit de sécurité et violation de données	4
C. Remédiation et correctifs	4
D. Méthodologie agile	4
E. Restitution	2
Annexe IA et qualité rédactionnelle	2
Total	20